Auftragsverarbeitungsvertrag (AVV)

AVV Nummer AVV-2026-

Parteien

Verantwortlicher (Kunde)

Firma

Vertreter

Adresse

Email Datenschutz

Auftragsverarbeiter

Christian Kummetat, Webschmiede - digitale Handwerkskunst
Meinertzhagener Str. 16, 53894 Mechernich, Deutschland
info@digitalehandwerkskunst.de · USt-IdNr. DE370109681

§ 1 Gegenstand, Dauer und Spezifikation

1. Gegenstand: Der Auftragsverarbeiter erbringt fuer den Verantwortlichen Leistungen im Rahmen des Hauptvertrages (Dienstleistungsvertrag / Managed Services). Hierbei verarbeitet der Auftragsverarbeiter personenbezogene Daten im Auftrag und nach Weisung des Verantwortlichen - insbesondere Automatisierung von Kundenanfragen, Lead-Routing, CRM-Synchronisation und messaging-basierte Kommunikation via n8n/APIs.

Leistungen AVV

2. Dauer: Die Dauer dieses Vertrages entspricht der Laufzeit des Hauptvertrages.
3. Art und Zweck: Erhebung, Erfassung, Strukturierung, Speicherung, Anpassung, Auslesen, Abfrage, Verknuepfung und Loeschung von Daten im Rahmen der eingerichteten Automatisierungs-Pipelines.

Betroffene: Kunden, Leads, Ansprechpartner, Mitarbeiter

Datenarten: Kontaktdaten, Kommunikation, Metadaten, Stammdaten

§ 2 Pflichten und Weisungsgebundenheit

1. Der Auftragsverarbeiter verarbeitet personenbezogene Daten ausschliesslich auf dokumentierte Weisung des Verantwortlichen. Dies gilt auch fuer Uebermittlungen an ein Drittland oder eine internationale Organisation.
2. Die Weisungen werden anfaenglich durch den Hauptvertrag und diesen AVV konkretisiert. Der Verantwortliche ist berechtigt, nachtraegliche Weisungen in Textform (z. B. per E-Mail) zu erteilen.
3. Der Auftragsverarbeiter informiert den Verantwortlichen unverzueglich, wenn er der Auffassung ist, dass eine Weisung gegen die DSGVO oder andere Datenschutzbestimmungen verstoesst.

§ 3 Vertraulichkeit und Personal

1. Der Auftragsverarbeiter sichert zu, dass alle mit der Verarbeitung betrauten Personen zur Vertraulichkeit verpflichtet wurden oder einer angemessenen gesetzlichen Verschwiegenheitspflicht unterliegen.
2. Die Verpflichtung zur Vertraulichkeit besteht auch nach Beendigung des Vertrages fort.

§ 4 Datensicherheit und TOMs

1. Der Auftragsverarbeiter trifft gemaess Art. 32 DSGVO alle erforderlichen technischen und organisatorischen Massnahmen, um ein dem Risiko angemessenes Schutzniveau zu gewaehrleisten.
2. Die konkreten Massnahmen sind in Anlage 1 geregelt (u. a. TLS/SSL, Zugriffsbeschraenkungen, automatisches Pruning von n8n-Execution-Logs).
3. Der Auftragsverarbeiter ist berechtigt, die Sicherheitsmassnahmen waehrend der Vertragslaufzeit anzupassen, sofern das vereinbarte Schutzniveau nicht unterschritten wird.

§ 5 Subunternehmer und KI-APIs

1. Der Verantwortliche erteilt dem Auftragsverarbeiter die allgemeine Genehmigung, weitere Auftragsverarbeiter gemaess Art. 28 Abs. 2 DSGVO einzusetzen. Die derzeit genehmigten Subunternehmer sind in Anlage 2 aufgefuehrt.

2. Dynamisches Aenderungsverfahren: Beabsichtigt der Auftragsverarbeiter, weitere Subunternehmer einzubinden oder bestehende zu ersetzen (z. B. neue KI-Nodes oder Schnittstellen in n8n), informiert er den Verantwortlichen mindestens 14 Tage vorher in Textform (E-Mail).

3. Der Verantwortliche kann der Aenderung aus wichtigem datenschutzrechtlichem Grund innerhalb von 14 Tagen widersprechen. Erfolgt kein Widerspruch, gilt die Zustimmung als erteilt.

4. KI-Schnittstellen (APIs): Sofern KI-Dienste eingesetzt werden, nutzt der Auftragsverarbeiter ausschliesslich Enterprise/API-Schnittstellen mit No-Training-SLA. Sensible Verarbeitung erfolgt vorrangig lokal oder ueber EU-Enterprise-Gateways.

§ 6 Rechte der Betroffenen

1. Der Auftragsverarbeiter unterstuetzt den Verantwortlichen bei Antraegen auf Wahrnehmung von Betroffenenrechten (Art. 12-22 DSGVO), soweit technisch moeglich und zumutbar.

2. Der Auftragsverarbeiter unterstuetzt bei der Einhaltung der Pflichten gemaess Art. 32 bis 36 DSGVO (Datensicherheit, Meldung von Verletzungen, Datenschutz-Folgenabschaetzungen).

§ 7 Audits und Kontrollrechte

1. Der Auftragsverarbeiter stellt dem Verantwortlichen alle erforderlichen Informationen zum Nachweis der Einhaltung zur Verfuegung.

2. Nachweise ueber TOMs koennen primaer durch Testate, Berichte oder Zertifikate unabhaengiger Instanzen erbracht werden (z. B. ISO/IEC 27001 Hetzner Online GmbH).

3. Vor-Ort-Inspektionen sind nach vorheriger schriftlicher Ankuendigung zulaessig, duerfen den Betrieb nicht unangemessen stoeren und keine Daten anderer Kunden gefaehrden.

§ 8 Loeschung und Rueckgabe

1. Nach Abschluss der Verarbeitungsleistungen oder nach Beendigung des Hauptvertrages loescht der Auftragsverarbeiter alle personenbezogenen Daten oder gibt sie zurueck – binnen 30 Tagen nach Vertragsende bzw. schriftlicher Weisung, sofern keine gesetzliche Speicherpflicht besteht. Backup-Kopien werden mit der ueblichen Backup-Rotation mitgeloescht, laengstens innerhalb weiterer 30 Tage.
2. Automatisch erzeugte System-Logs (n8n Execution Logs) werden gemaess Retention-Guidelines nach spaetestens 7 bis 14 Tagen automatisch bereinigt (EXECUTIONS_DATA_PRUNE=true).

§ 9 Schlussbestimmungen

1. Sollten einzelne Teile unwirksam sein, bleibt die Wirksamkeit der uebrigen Bestimmungen unberuehrt.
2. Es gilt ausschliesslich deutsches Recht. Anlage zum Dienstleistungsvertrag.

Anlage 1: Technische und Organisatorische Massnahmen

Vertraulichkeit
- Zutrittskontrolle: ISO-27001-zertifizierte Rechenzentren (Hetzner, DE).
- Zugangskontrolle: SSH-Keys, 2FA fuer Server- und n8n-Administration, Passwort-Manager.
- Zugriffskontrolle: Rollenbasierte Rechte; Mandantentrennung durch dedizierte Docker-Container.

Integritaet
- Weitergabekontrolle: Transportverschluesselung (HTTPS/TLS 1.3) zwischen Webhooks, n8n, DocuSeal und APIs.
- Verschluesselung at Rest: Datenbanken und n8n-Credentials (N8N_ENCRYPTION_KEY).

Verfuegbarkeit
- Verfuegbarkeitskontrolle: Automatisierte naechtliche Backups auf verschluesselte Storage-Locations (DE).
- Wiederherstellbarkeit: Disaster-Recovery-Routinen fuer Docker-Container und Datenbanken.

Ueberpruefung
- Security-Updates fuer Server-OS, Docker-Engine und n8n.
- Automatisiertes Pruning unbenoetigter Ausfuehrungsdaten (max. 7-14 Tage).
- KI-Transparenz: Dokumentation lokal (Ollama) vs. EU-Enterprise-API.

Anlage 2: Genehmigte Subunternehmer

Weitere Anbieter nur nach § 5 Abs. 2-3 (14-Tage-Fiktionsklausel). Stand: Vertragsabschluss.

Unterschriften

Datum Kunde AVV

Datum Webschmiede AVV

Unterschrift Kunde AVV

Unterschrift Webschmiede AVV